

This report covers one full **Build** → **Audit** → **Remediation** cycle on the unbuilt C.A.R.E surface, performed under the project framework (§0 understanding-first; AMD-006 four-layer gate; §2 diagnose-before-patch; §3.1–§3.6 thesis-core). It records what shipped, the self-audit and its fixes, and — most importantly — **everything still left to build**, ranked by whether it blocks launch.

CYCLE-1 RESULT
4 features built + a continued proactive audit (§1.5.2) that **closed the role-attribution class (6/6 tools, founder-verified)** and fixed real defects in the least-exercised channels (email, extension). Type-safe project-wide, full suite green. All on `main`.

THE ONE THING BETWEEN "BUILT" AND "CUSTOMERS USING IT"
LAUNCH BLOCKER The **entitlement write-path** (A1+B1) — every tenant is `locked`; no flow grants access. Founder pricing decision. Not part of this cycle's scope.

1 · BUILT THIS CYCLE

FEATURE	WHAT SHIPPED (FILE BY FILE)	FRAMEWORK	STATUS
Live Monitor was a 31-line "Sprint 3d" stub	<code>0192</code> visitor-presence table (RLS, additive) · <code>care.ts</code> touch/fetch (purge + window) · <code>POST /widget/presence</code> (embed-token auth) · <code>GET /monitor/visitors</code> (agent-auth, tenant-scoped) · widget anon heartbeat · <code>monitor/page.tsx</code> polling view.	A16/A28 (follows the <code>care_agent_state</code> presence precedent, not a new realtime mechanism) · §3.4 anonymous, non-surveillant	BUILT needs <code>0192</code> + browser
Decision Dialogue "This is not working" — dead link	Root cause: link → <code>/dashboard/decisions/new</code> which never existed (404). Repointed to the real page + <code>GET ../decision-seed</code> (agent-auth, IDOR-scoped) + pure <code>decisionSeed.ts</code> builder (7 tests) + page seeds Situation with the customer's own words.	AMD-006 L3 (delivers the button's promise, not just avoids 404) · §3.3 grounded in what was asked	BUILT needs browser
Read-receipts "Sprint 2" stub	Client-side <code>lastViewedAt</code> → unread dot on the collapsed bubble. Post-audit correction: the dot could never light without a collapsed-state fetch, so a gentle 30s poll (active-session only, tab-paused) was added; and the dot was missing entirely on <code>CareEmbeddedWidget</code> (the customer-facing one) — built there too (A21 parity).	AMD-006 L2 (now actually lights) · A21 (both surfaces)	BUILT x2 needs browser
§A11 aggregator "Sprint 3c" stub	"What we've noticed" panel wired to <code>customerPatterns.ts</code> (13 tests) + <code>fetchCustomerPatterns</code> + <code>GET ../customer-patterns</code> (IDOR-scoped). Counts only, threshold-gated.	A11 counts-not-verdicts · §3.2 withheld below 3 conversations · §3.5 resolved by durable timestamp	BUILT needs data

2 · AUDIT & REMEDIATION

ID	SEV	FINDING & EVIDENCE	RESOLUTION
A1	MEDIUM	<code>/widget/presence</code> had no rate-limit, while all 3 sibling public widget routes do (class-checked via A21).	FIXED Added <code>rateLimit</code> 120/min/IP (generous for a heartbeat; bounds a rotating-visitorld flood).
A3	LOW	Monitor polled every 5s even when the tab was hidden (AMD-006 L1 efficiency).	FIXED Polls only while visible; refreshes on return.
A5	LOW	Aggregator rendered raw machine topic values (<code>account_login</code>) — AMD-006 L4.	FIXED <code>humanizeConcern</code> → "Account login".
A2	LOW	Presence stores an unvalidated <code>conversationId</code> .	DOCUMENTED "Open chat" target is agent-auth + tenant-scoped (cross-tenant → 404) → no leak; fix cost (per-heartbeat query) > risk (A15).
A4	LOW	<code>document.referrer</code> host-page accuracy is imperfect (AMD-006 L2).	FIXED Host script (<code>care-widget.js</code>) now <code>postMessages</code> the current page on load + SPA nav; the

ID	SEV	FINDING & EVIDENCE	RESOLUTION
			widget prefers it over <code>document.referrer</code> . Non-breaking; auto-propagates to existing embeds.

Verified-sound on inspection (not just assumed): tenant-scoping on all 3 new read endpoints (no cross-tenant leak); the presence table is ephemeral infra state, not a §3.1 domain event (matches `care_agent_state`); the aggregator is counts-only + threshold-gated; every new data-layer function degrades gracefully if its migration is unapplied (A34).

2B · CONTINUED AUDIT & FIXES — ROLE ATTRIBUTION + THE QUIET CHANNELS

After the cycle above, a proactive AMD-006 §1.5.2 sweep (THINK-then-search across shared logic) found real, customer-facing defects in the code paths that get less traffic than the widget. These were fixed, not just flagged. The role-attribution item is the one you reported and verified in-session.

AREA	FINDING & FIX	STATUS	COMMITTS
Role attribution you reported: Spawn called you (the C.A.R.E user) the customer	Root cause (§2): write-as-agent tools received the scanned thread as one unlabeled blob with no "who is the agent" anchor, so the LLM couldn't attribute roles. The 2026-07-23 "universal" fix was <i>not</i> universal (memory corrected). Fix: agent-name lookup + a WHO-IS-WHO anchor injected at the route layer, then swept across the whole class — all 6 tools (co-pilot, spawn, formulate, coach, summarize, dissect) — and locked with regression tests.	CLASS CLOSED 6/6 FOUNDER-VERIFIED (spawn)	86bc7254 2a269afb 2248a188 3a707f51 56b4482a
Email channel least-exercised parallel of the widget — 3 real bugs	(1) The AI responder ran context-blind — it was passed <code>recentTurns:[]</code> , so it never saw the thread history → shared <code>buildRecentTurns</code> helper (widget + email now identical). (2) AI replies were stored but never emailed → <code>dispatchOutboundEmailReply</code> wired (dormant-safe: no-ops until Postmark is set). (3) A handoff with an empty AI reply left the customer in silence → <code>resolveEmailReplyBody</code> emits the handoff notice.	FIXED x3 needs Postmark + browser	2c22d279 80bc1b5a 78bbce10 dc9eac88
Chrome extension stale-context truncation	The scanned-thread cap kept the oldest 20k chars, not the most recent (<code>slice(0,N)</code> → <code>slice(-N)</code>) — so on a long thread the tools reasoned from the top of the page, not the live exchange.	FIXED	9ae8cd2d
Sales Coach	Attribution verified sound (no rep/customer inversion). Separately: the attribute route leaked an internal debug string (flags + error text + raw LLM output) into every production response → gated to non-production.	FIXED	c4097237
Live Monitor follow-on to the cycle build	Added session duration ("on site 4m") next to last-active — the "someone's been stuck on this page a while" signal, which is the whole point of the monitor.	BUILT needs browser	f87227f1

Verified-sound in the same sweep (inspected, not assumed): §3.1 event-immutability system-wide, §3.2 understanding gate, CSV formula-injection neutralisation, CRM/admin authz gating, care-config prompt-injection (admin-only writes), embed snippet + multi-tenant routing, LLM-route rate-limiting, voice per-call cost caps, migration sequence 0001–0192 + idempotency, double-entry balance (DB constraint trigger, deferred). The one money-bug held for your decision: FX per-line base rounding vs the exact-equality balance check (latent — no currency picker ships yet).

3 · WHAT'S LEFT TO BUILD — THE WHOLE C.A.R.E MAP

Legend: **BLOCKER** nothing launches without it **FOUNDER-GATED** needs your decision **ENHANCEMENT** works today, better later **OPS** config/apply

ITEM	WHAT & WHY	TYPE	SOURCE
Entitlement write-path (A1+B1)	Every tenant is <code>locked</code> ; no flow writes <code>plan=pro</code> or starts a trial. The extension + gated features are unreachable by any customer. Needs the trial mechanism + paid-unlock (Stripe/tier map). This is a pricing decision.	BLOCKER GATED	settings/widget:907 "Stripe + tier upgrade ships in Sprint 7"; FOUNDER-ACTION-QUEUE #1
Per-tenant AI-cost cap	4 AI-ingress surfaces (widget LLM, inbound email, voice TTS, voice STT) bound cost below the tenant level → distributed abuse = unbounded bill. One windowed cap closes all 4. Needs per-plan numbers.	GATED	FOUNDER-ACTION-QUEUE 6b
AI human/AI honesty disclosure	The customer widget AI is told to "sound like a real person" with no "be honest if asked human/AI" instruction → SB 1001 / EU AI Act exposure.	GATED	FOUNDER-ACTION-QUEUE 8d

ITEM	WHAT & WHY	TYPE	SOURCE
Embeddings upgrade	Read-Phase similarity, Summarize, and Co-Pilot keyword-extraction use crude keyword matching. Works today; embeddings would sharpen "similar past resolutions."	ENHANCE	read:72/126, summarize:150, co-pilot:258 ("Sprint 5/6")
Durability auto-resolve worker	A background worker that auto-resolves "held" problems and re-opens reopened ones (the \$3.5 moat loop). The hourly sweep exists; the auto-resolve worker doesn't.	ENHANCE OPS	durability:14 ("Sprint 5"); needs CRON_SECRET
Widget load-events analytics BUILT ✓	Traffic + wrong-origin (token-abuse) visibility now in widget settings — e0af75af .	DONE	was settings/widget "Sprint 7"
Inline Decision Dialogue in thread	Today "Open as Decision Dialogue" routes to the decisions page (seeded). Full inline-in-thread dialogue (like the chats surface) remains a follow-up.	ENHANCE	ConversationsApp comment

4 · FOUNDER ACTIONS TO MAKE THIS CYCLE LIVE

APPLY MIGRATIONS

- 0188 handover capture · 0189 entitlement column · 0190 gate fail-closed · 0191 budget-variance
- 0192 **visitor-presence** (this cycle) — additive, RLS, zero-risk
- Run `npm run db:apply` (needs the pooler string in `SUPABASE_DB_URL`).

BROWSER-VERIFY (UNTESTED)

- Monitor: heartbeat → row → poll loop; host-page label
- Decision Dialogue: click → seed → banner; IDOR 404
- Read-receipt: dot lights on reply, clears on open
- Aggregator: counts render at ≥3 conversations

Honesty note (\$5 / verification discipline): every "BUILT" item above is verified only to the level stated — `tsc` clean and unit tests green. The end-to-end behaviour is **untested** until run in a live browser against an applied DB; completion is your confirmation, not mine.